

1. Explain Kerberoasting

Kerberoasting is an attack technique used in Active Directory environments to obtain service account passwords. Attackers request a Kerberos service ticket (TGS) for a service account. Since the ticket is encrypted using the service account's password hash, the attacker can extract the ticket and attempt to crack it offline using password-cracking tools.

If the service account has a weak password, the attacker may recover the password and gain unauthorized access to important systems.

How Kerberoasting Works

1. The attacker gains access to a domain user account.
2. The attacker requests a Kerberos service ticket (TGS).
3. The ticket is extracted from memory.
4. The encrypted ticket is cracked offline.
5. If successful, the attacker obtains the service account password.

Prevention

- Use strong, complex passwords for service accounts.
- Implement Group Managed Service Accounts (gMSA).
- Monitor unusual Kerberos ticket requests.
- Enable multi-factor authentication where applicable.

2. Describe Golden Ticket Attacks

A Golden Ticket attack occurs when an attacker compromises the **KRBTGT** account in Active Directory. The KRBTGT account is responsible for signing Kerberos Ticket Granting Tickets (TGTs).

If attackers obtain the KRBTGT password hash, they can create fake Kerberos tickets that allow them to impersonate any user, including Domain Administrators.

Impact

- Full control of the Active Directory domain.
- Ability to access any system.
- Long-term persistence.
- Bypass normal authentication controls.

Prevention

- Protect Domain Controllers.
- Limit Domain Administrator privileges.
- Regularly rotate the KRBTGT account password if compromise is suspected.
- Monitor abnormal Kerberos ticket activity.

3. Explain DCSync Attacks

A DCSync attack allows an attacker to impersonate a Domain Controller and request password hashes from Active Directory.

Instead of attacking the Domain Controller directly, the attacker abuses Active Directory replication features to retrieve password hashes, including the KRBTGT account.

How It Works

1. The attacker gains high privileges.
2. The attacker requests replication data.
3. Active Directory sends password hashes.
4. The attacker uses the hashes for credential theft or further attacks.

Prevention

- Restrict replication permissions.
- Monitor Active Directory replication requests.
- Limit privileged accounts.
- Enable advanced security auditing.

4. Analyze LDAP Abuse Indicators

Scenario

A SOC analyst notices an unusually high number of LDAP queries coming from a standard employee workstation. The queries are requesting information about user accounts, group memberships, computers, and administrative privileges.

Further investigation shows that the employee has never performed these types of searches before. Shortly afterward, multiple failed login attempts occur across several servers.

Analysis

Attackers often use LDAP enumeration after gaining initial access to understand the Active Directory environment. They collect information about users, privileged accounts, groups, and computers before attempting privilege escalation or lateral movement.

In this scenario, the excessive LDAP queries suggest reconnaissance activity inside the network.

Indicators of LDAP Abuse

- Large numbers of LDAP queries.
- Enumeration of Domain Admin accounts.
- Searches for privileged groups.
- Requests for Service Principal Names (SPNs).
- Unusual LDAP activity from non-administrative workstations.
- LDAP queries occurring outside normal business hours.

Response Steps

- Investigate the source workstation.
- Review user authentication logs.
- Isolate the affected device if necessary.
- Reset compromised credentials.
- Monitor for lateral movement.
- Update SIEM detection rules.

5. Research Privilege Escalation Methods

Privilege escalation is the process by which an attacker gains higher permissions after initially compromising a system. The goal is to obtain administrative or system-level access.

Common Privilege Escalation Methods

1. Weak Passwords

Attackers crack or guess administrator passwords to gain elevated privileges.

2. Credential Dumping

Tools such as Mimikatz can extract passwords and NTLM hashes from memory.

3. Pass-the-Hash

Instead of knowing the password, attackers authenticate using stolen NTLM password hashes.

4. Exploiting Software Vulnerabilities

Attackers take advantage of unpatched operating system or application vulnerabilities to gain higher privileges.

5. Misconfigured Permissions

Improper file, folder, or service permissions may allow attackers to execute code with elevated privileges.

6. Token Impersonation

Attackers steal or impersonate security tokens belonging to privileged users.

Prevention

- Apply security patches regularly.
- Use strong password policies.
- Enable multi-factor authentication.
- Restrict administrative privileges.
- Monitor privileged account activity.
- Implement the principle of least privilege.
- Use Endpoint Detection and Response (EDR) solutions.